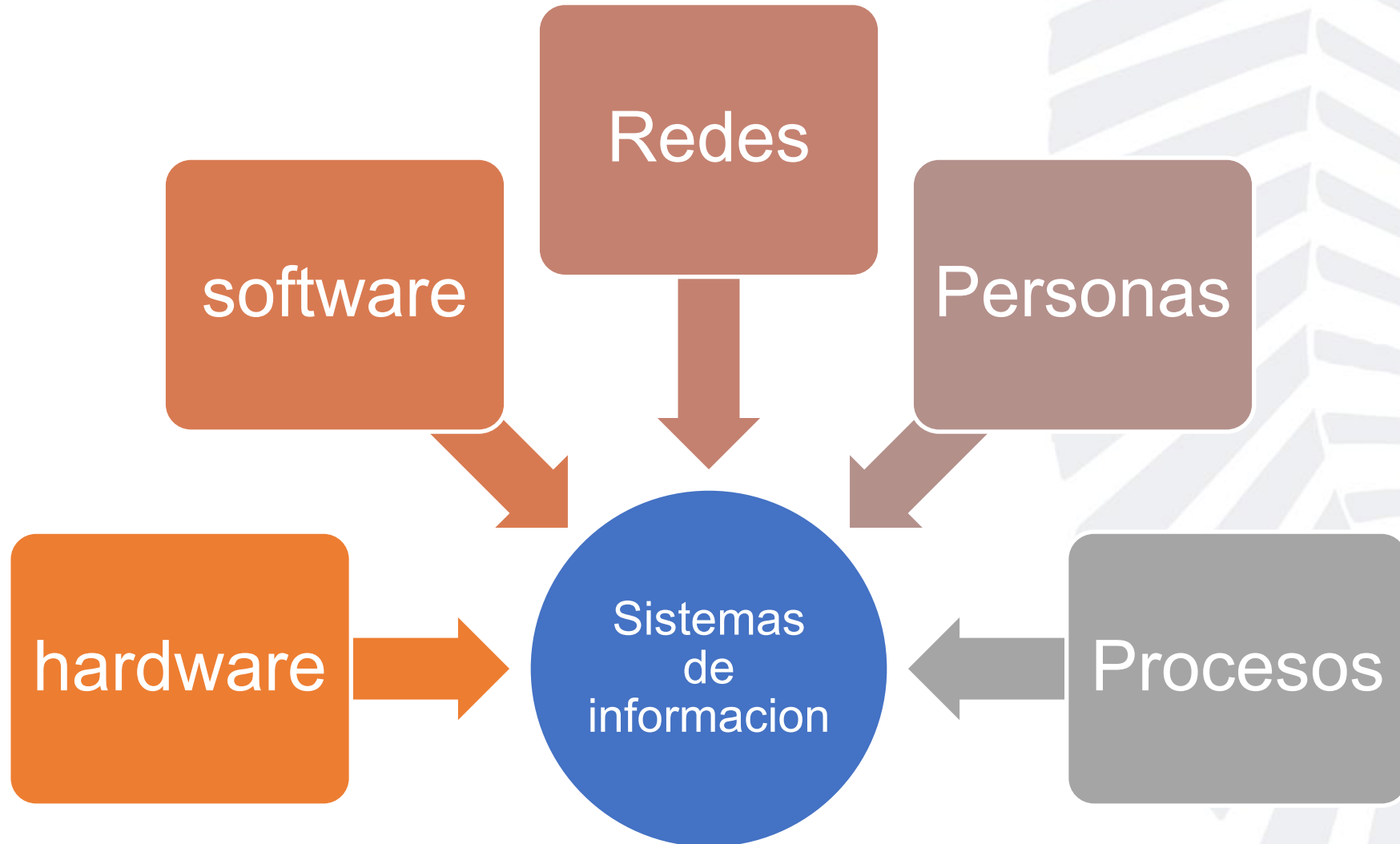




UNIVERSIDAD NACIONAL
RAÚL SCALABRINI ORTIZ
SAN ISIDRO

Un Sistema de información se define como componentes interrelacionados trabajando juntos para recolectar, procesar, almacenar y diseminar información que brinde soporte a la toma de decisiones, coordinación, control, análisis y visualización en una organización.

Componentes



Sistemas de Información

Personas – Procesos

SISTEMA

USUARIO

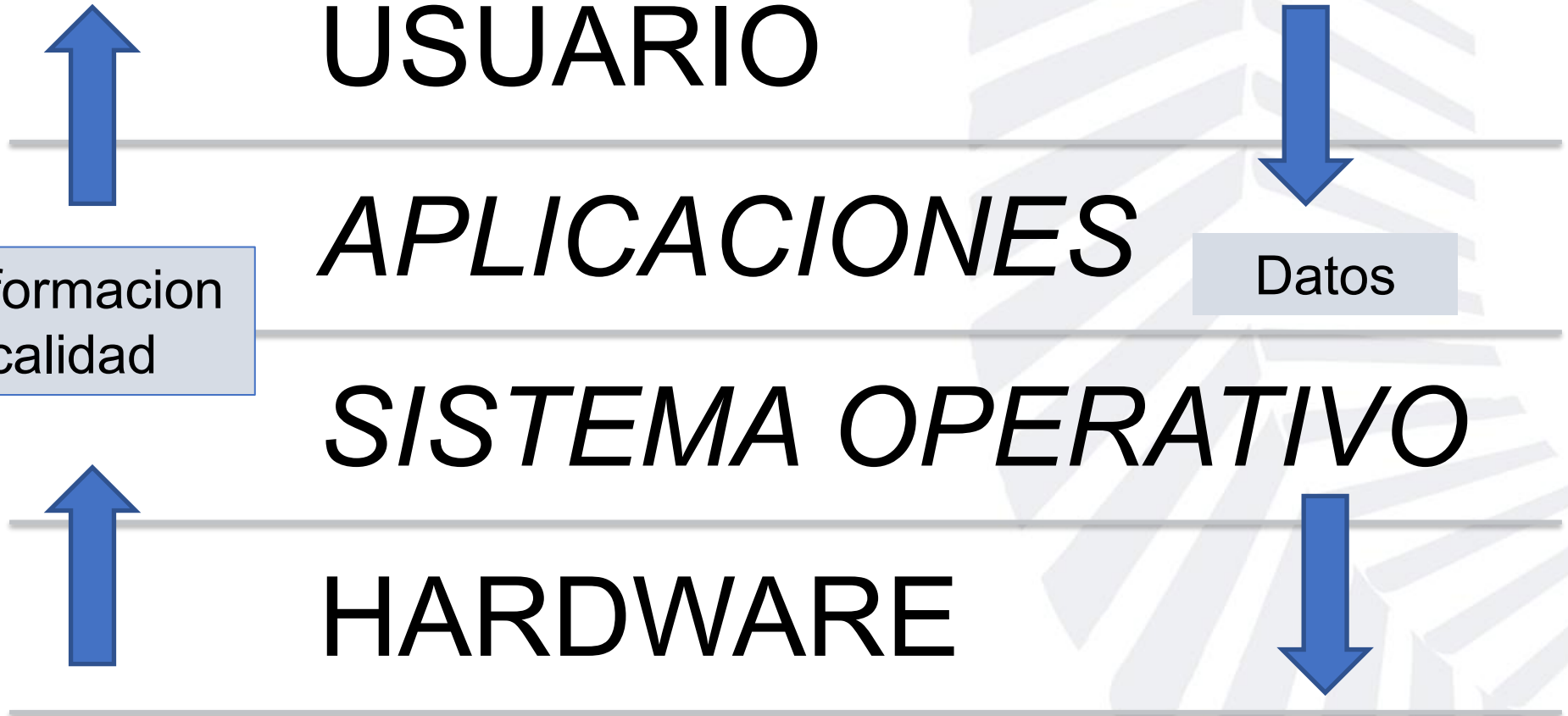
APLICACIONES

Informacion
calidad

Datos

SISTEMA OPERATIVO

HARDWARE





UNIVERSIDAD NACIONAL
RAÚL SCALABRINI ORTIZ
SAN ISIDRO

SEGURIDAD DE LA INFORMACION



Datos → *Información*



- Información: activo corporativo estratégico, crítico para mantener sustentable las operaciones de la organización.
- Pensar su valor y como protegerla, asegurarla como parte del negocio



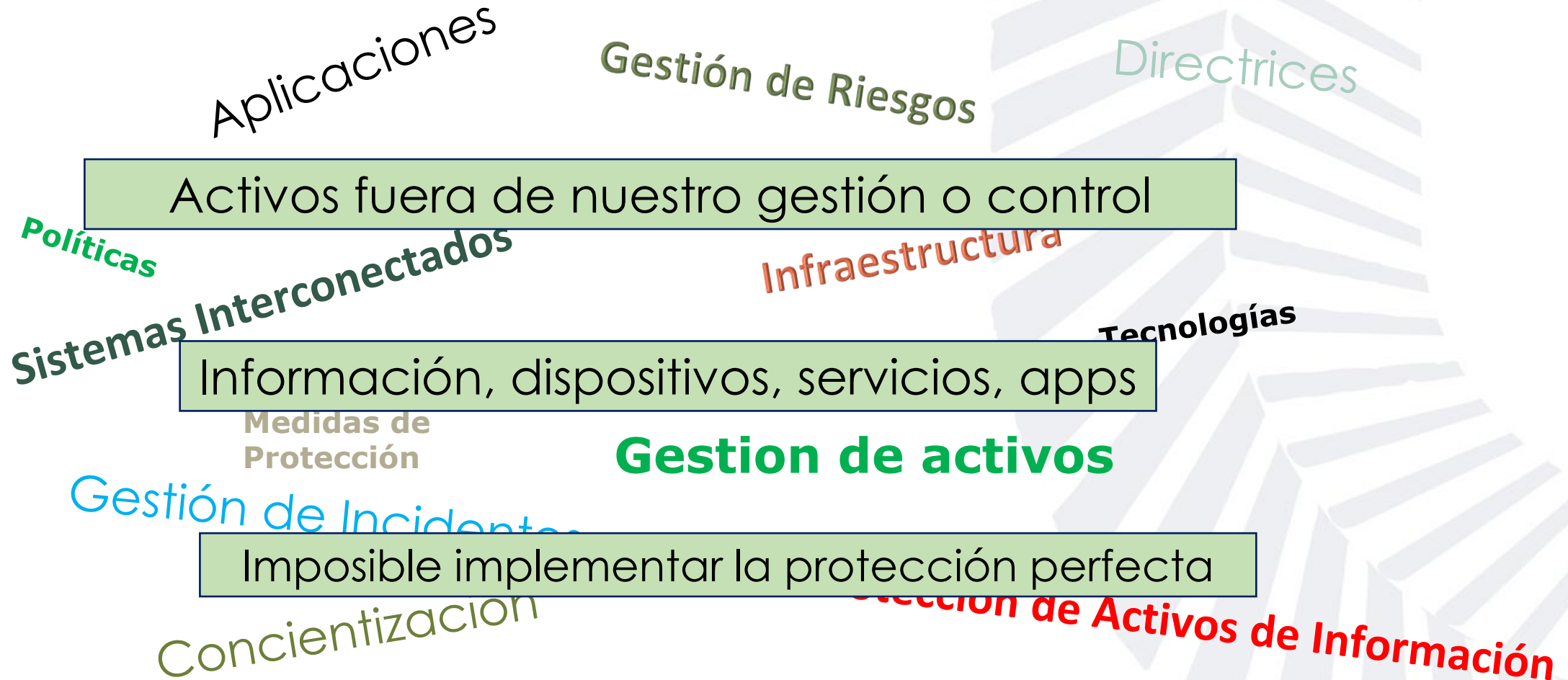
- PERSONAS
- INFRAESTRUCTURAS CRITICAS
- BYOD
- NUBE
- ORGANIZACIONES
- SISTEMAS
- SERVICIOS
- DISPOSITIVOS MOVILES
- INTELIGENCIA ARTIFICIAL
- IOT
- IDENTIDAD DIGITAL
- BIG DATA
- REDES SOCIALES
- PROVEEDORES

se puede proteger TODO?

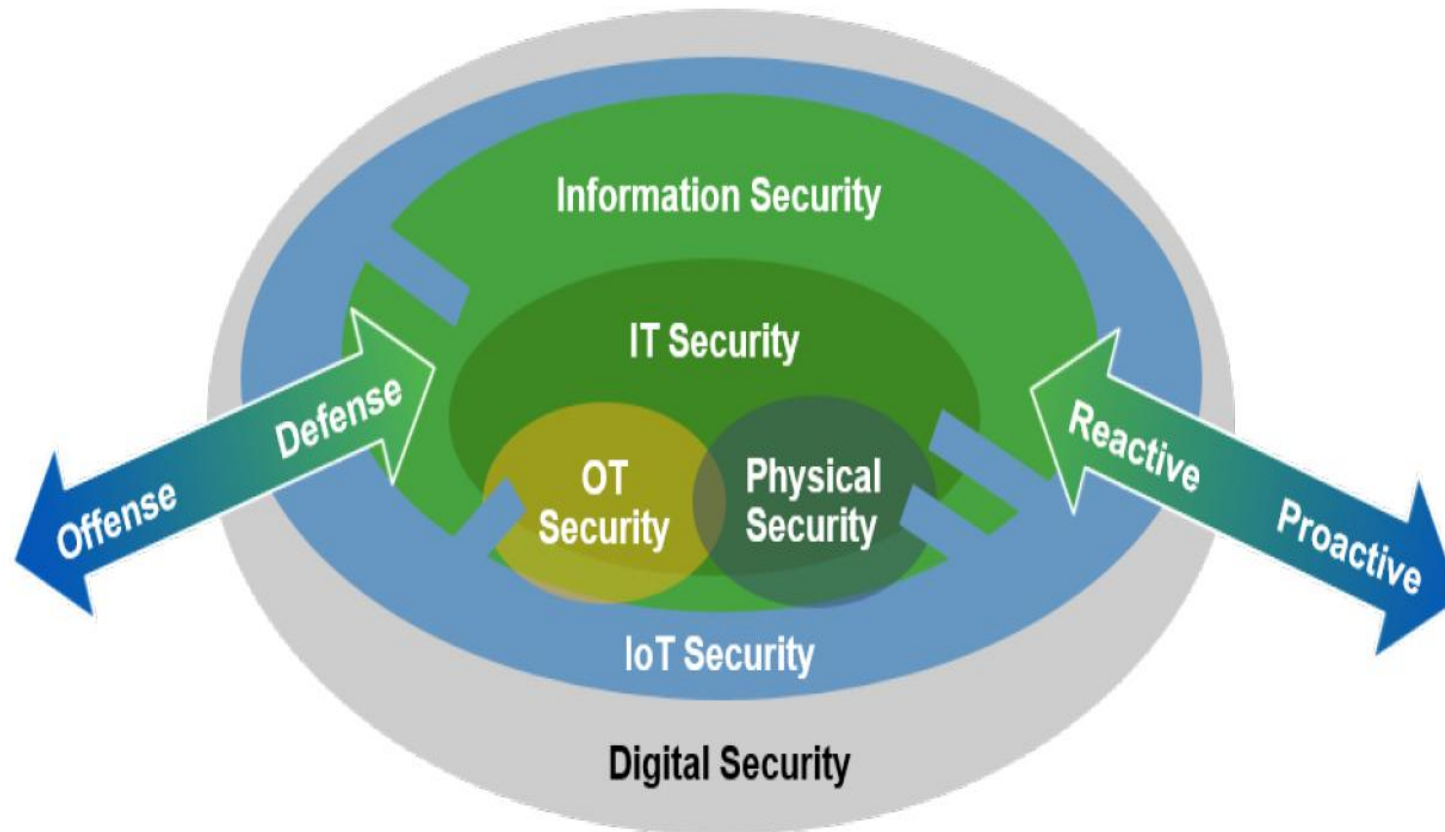


- *WIFI*
- *REDES SOCIALES*
- *CLOUD (IAS-PAS-SAS)*
- *PROTECCION ATAQUES DDOS*
- *PERIMETRO INCIERTO*
- *MULTIPLATAFORMAS*
- *MULTIPLES ACCESOS*
- *MULTIPLES DISPOSITIVOS*
- *BIG DATA - DATA ANALITICS*
- *DIGITALIZACION*
- *INFRAESTRUCTURAS Y SERVICIOS EXPUESTOS.*
- *REPUTACION, COMPORTAMIENTO DIGITAL.*
- *SEGURIDAD ORIENTADA AL DATO*
- *MULTIPLES PROVEEDORES Y SERVICIOS DE TERCEROS*

Gestión de Seguridad **TECNOLOGIA ,PERSONAS Y PROCESOS**



En el camino a la seguridad digital



De que tenemos que protegernos ?

Tecnología como el objetivo del ataque

- **Malware** , software malicioso, es cualquier programa que esta diseñado para robar o destruir datos y sistemas
 - ***Viruses and worms*** : es codigo que se replica para deetruir datos. Un virus requere un habitat para desparramarse como un ejecutable,
 - ***Spyware*** es un software que recolecta datos, generalmente pesronales y los envia sin que sepas.
 - ***Ransomware*** es un tipo de malware que infecta tu computadora y encripta los datos , requiriendo luego un pago del dueño para que puedas acceerlo otra vez.

Robo de identidad, ingeniería social, hacking, phishing, spoofing, piratería de software

- **Robo de identidad**, cuando un criminal gana acceso a tu información personal y la usa sin tu conocimiento .
- **Ingeniería Social** , cuando los criminales convencen a los individuos que le envíen información confidencial que pueden usar luego en un crimen.. For example, someone phones you posing as a customer service representative asking for your banking log-on information.
- **Hacking** es cuando acceden a tu computadora sin permiso.
- **Phishing** ocurre cuando un usuario recibe un e-mail que parece venir de un remitente confiable , como un banco o el empleador . El usuario se le pide que clique en un link y que ponga sus credenciales en un website que imita al website genuino , siendo las credenciales capturadas por el atacante.
- **Spoofing** suplantación. La idea detrás del ataque es hacerse pasar por una persona o empresa con fines maliciosos, para convencerte de hacer algo que ponga en peligro tu ciberseguridad.
- **Piratería** , que es la copia y distribución ilegal de sw.



OTRAS TACTICAS usadas para generar ataques de ciberseguridad

Users/Administrators

- Bad apple
- Social engineering
- Phishing
- Weak or easily compromised passwords
- Careless or uninformed user (insecure "sharing" settings, no encryption, software updates turned off, poor configuration)



Network

- Sniffers, compromised relays, and equipment
- DNS redirects
- Weak user authentication/open hotspots

Physical Threats

- Dumpster diving
- Eavesdropping (key loggers, cameras, mics, devices mailed or left on premises)
- Destruction of property



Client/Software

- OS holes
- Application weaknesses
- Languages in applications
- Applets in applications

Computing Hardware

- Removable media (USB, DVD, etc.) insert malware
- PC/device theft
- Physical access (break into room)



Server software

- OS holes
- Application weaknesses
- Languages in applications
- Applets in applications
- Applications poorly coded (allow for SQL injection, cross-site scripting)
- Unfederated systems (entering one system allows access to others)

- Tecnología
- Sw-hw-redes
- Personas
- procesos

TRIADA CID Y.....



PRIVACIDAD
SEGURIDAD FISICA
CONFIABILIDAD

La **confidencialidad** se refiere a la restricción del acceso a la información a personas autorizadas, asegurando su privacidad.

La **integridad** garantiza que la información sea precisa, completa y confiable, sin modificaciones no autorizadas.

La **disponibilidad** asegura que la información y los recursos estén accesibles para los usuarios autorizados cuando la necesiten, evitando interrupciones o pérdidas



Ciberhigiene:

- Control de acceso, Autenticación y autorización, factores, complejidad de las claves, cambiarlas regularmente
- Encriptación
- Backups.
- Seguridad en la red : Fws, IDS, IPS.
- Seguridad Física
- Seguridad en los desarrollos.
- Política de uso de dispositivos móviles
- Tecnología, personas y procesos

SCA / Strong Customer Authentication

Dos o más factores de autenticación



01

Algo que sabes

Como una contraseña o pin web



02

Algo que eres



Reconocimiento facial



Reconocimiento voz



Reconocimiento de firma



Reconocimiento de huella
dactilar



03

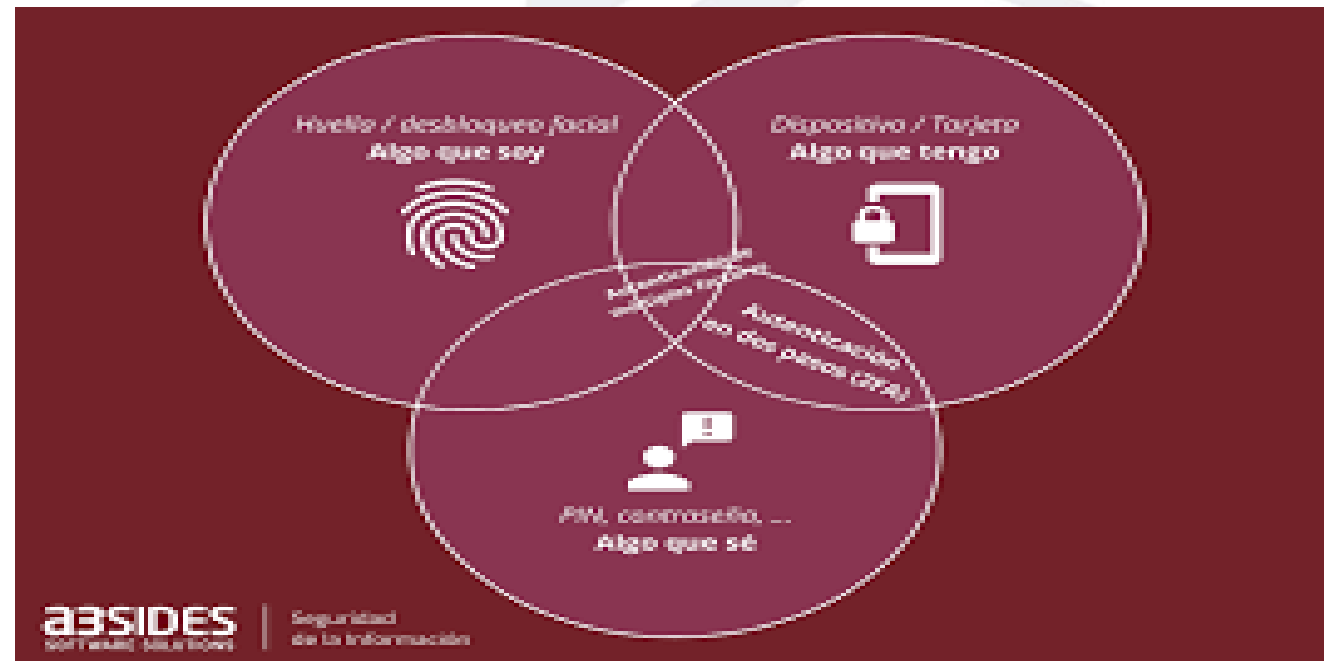
Algo que tienes

Como una tarjeta o móvil

AUTENTICACIÓN DE MÚLTIPLES FACTORES



Doble factor de autenticación = Autenticación Fuerte?



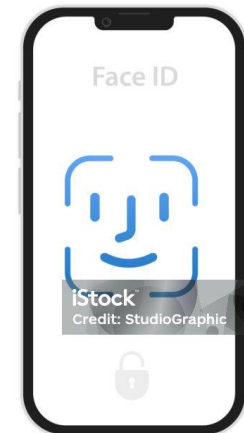
AUTENTICACIÓN DE MÚLTIPLES FACTORES



Algo que
tienes

Algo que
eres

Algo que
sabes



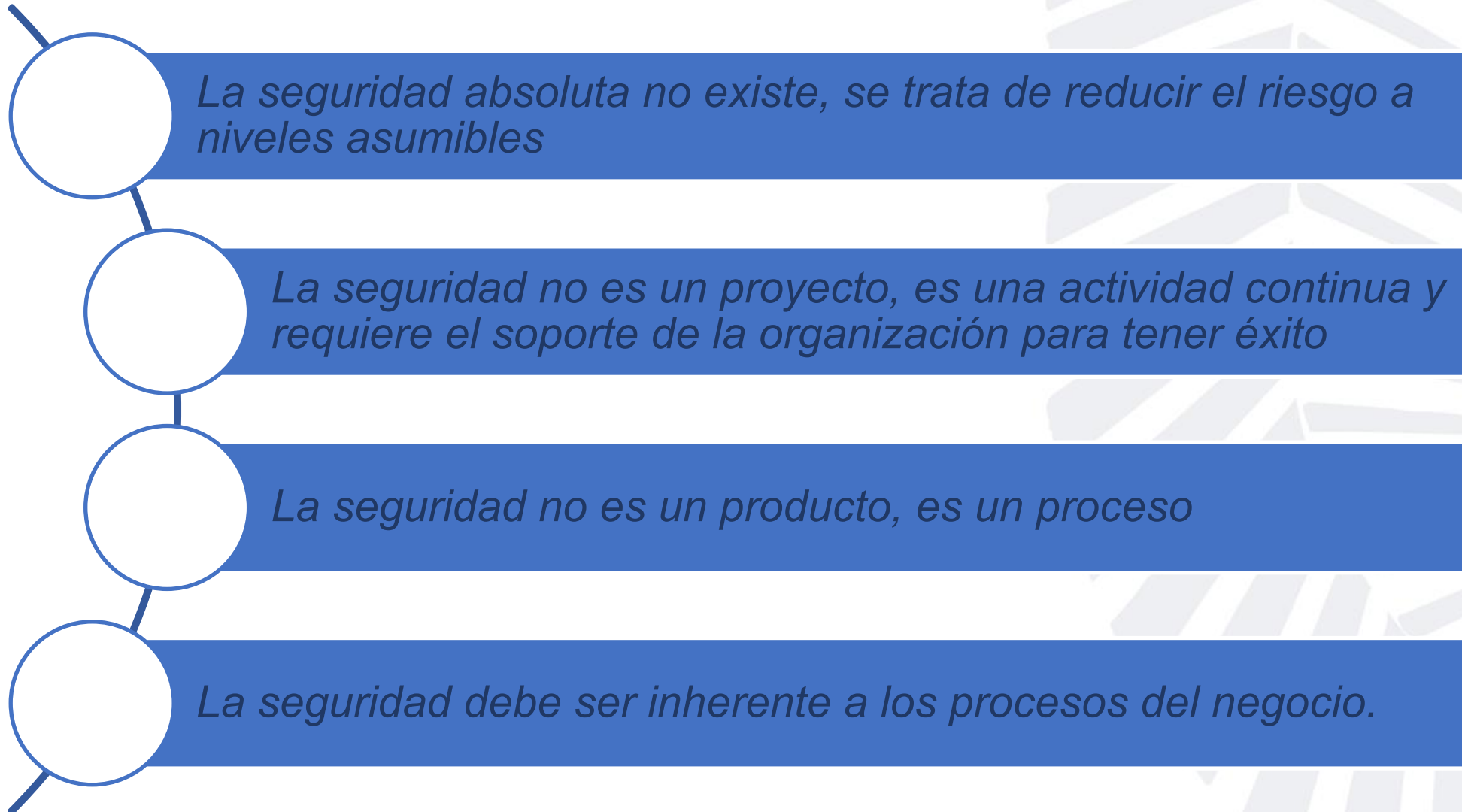
Ciberhigiene

- Mantener el sw actualizado
- Instalar antivirus y mantenerlo al día
- Estar conciente de donde te conectas
- Backup de tus datos e informacion
- Que tus claves sean únicas, de longitud y fuertes.
- Sospecha de los correos con links o attaches

Ciberhigiene

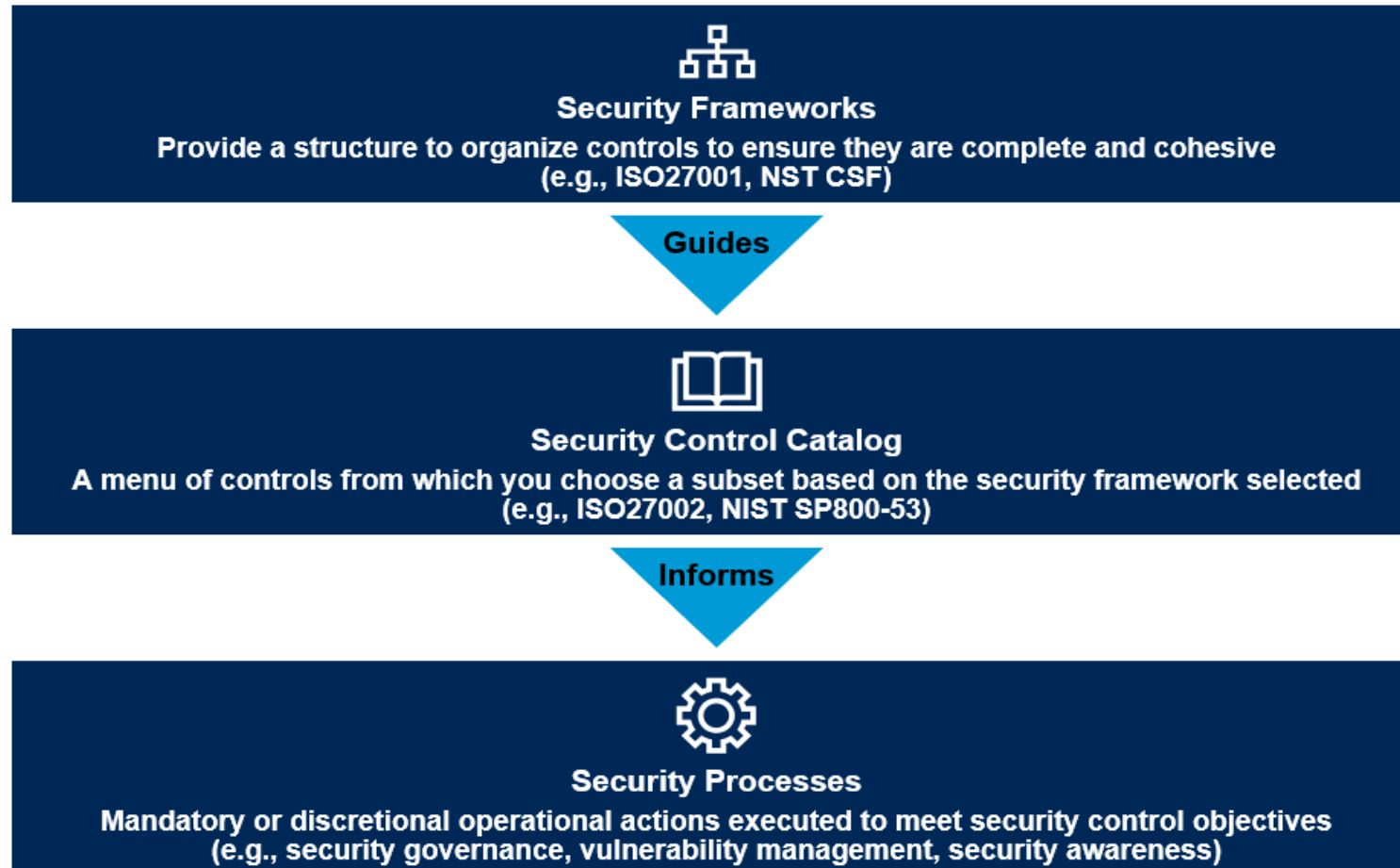
Controles básicos recomendados para organizaciones

Autenticación fuerte	Entrenamiento y concientización	Encriptar y backuppear información	Seguridad en la red e infraestructura informática
Asegurar las nubes y servicios tercerizados	Gestión de incidentes	Security operations center	Seguridad física
Seguridad en el Desarrollo	Actualizar sw de base, últimos parches	Monitoreo y control de Seguridad	Asegurar medios portables
	Internet, extranet, intranet	APIs, sitios web	



Como Seleccionar los controles

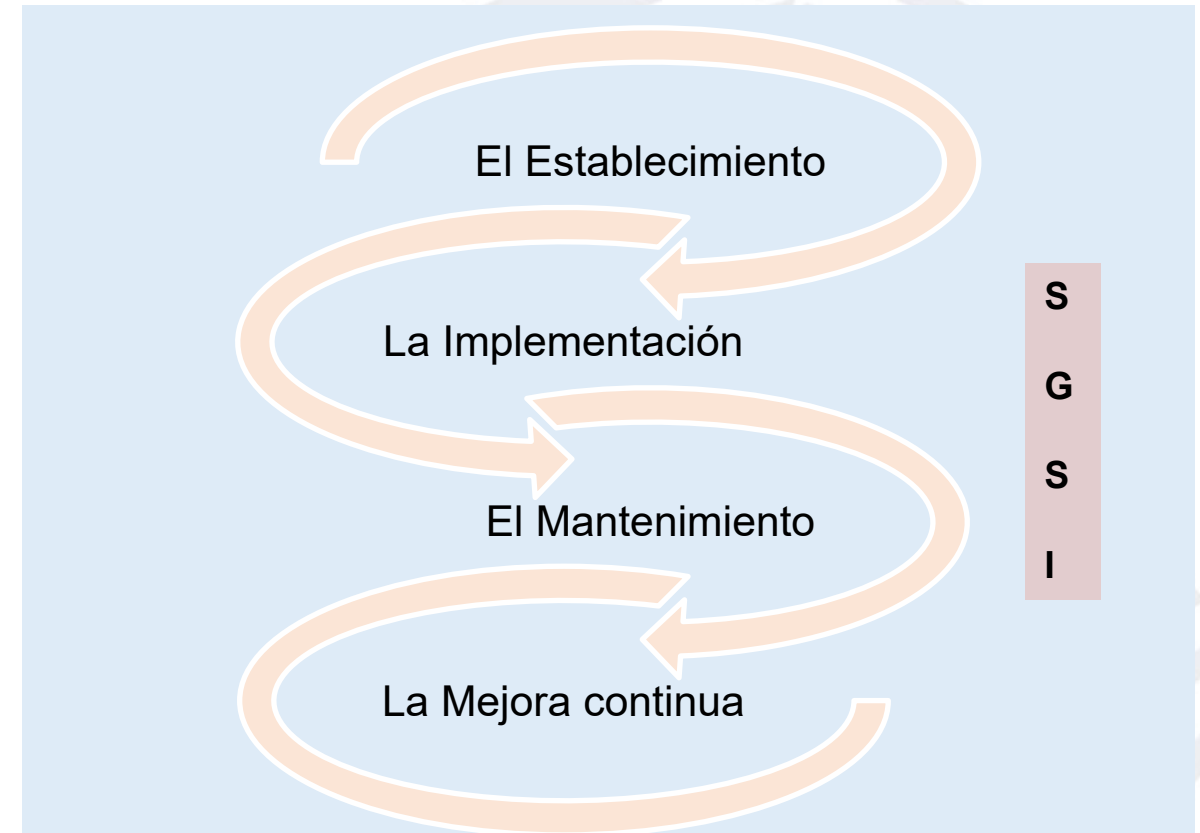
Relationship Between Security Management Frameworks, Control Catalogs and Security Processes



Especifica requisitos para:

Dentro del contexto de la organización.

Incluye los requisitos para la *evaluación y tratamiento de los riesgos* de la información adaptados a las necesidades de la organización.



ISO/IEC 27001- Requisitos para la implementación de un SGSI:

Términos y Definiciones: (remite a ISO/ 27000)

Principales dimensiones de la seguridad de la información:

Confidencialidad.

Se garantiza que la información sea accesible solo a aquellas personas autorizadas.

Integridad.

Se resguarda la exactitud y totalidad de la información y los métodos de procesamiento.

Disponibilidad.

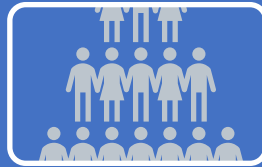
Se garantiza que los usuarios autorizados tengan acceso a la información y a los recursos asociados cuando lo requieran

Controles Anexo A ISO 27001 - 2022



Controles organizacionales

- 37 controles



Controles orientados a las personas

- 8 controles



Controles físicos

14 controles



Controles Tecnológicos

- 34 controles

Anexo A 27002- 2022

Controles Organizacionales

- ◆ **Objetivo:** definir una política de seguridad de la información, roles y responsabilidades, segregación de funciones.
- ◆ **Objetivo:** proveer orientación y soporte de la gerencia sobre seguridad de la información de acuerdo a los requerimientos del negocio, leyes y reglamentos relevantes.
- ◆ **Objetivo:** establecer un marco de gestión para iniciar y controlar la implementación y operación de seguridad de la información dentro de la organización.
- ◆ **Objetivo:** garantizar la seguridad del trabajo remoto y el uso de dispositivos móviles
- ◆ **Objetivo:** Identificar los activos de la organización y definir las responsabilidades de protección pertinentes.
- ◆ **Objetivo:** asegurar que la información recibe el nivel de protección adecuado, según su importancia para la organización.
- ◆ **Objetivo:** prevenir la divulgación no autorizada, modificación, eliminación o destrucción de la información almacenada en los medios.
- ◆ **Objetivo:** implementar inteligencia en amenazas

Anexo A 27002- 2022

Controles Organizacionales

- ◆ **Gestión de incidentes de seguridad de la información.**
 - ◆ **Gestión de incidentes de seguridad de la información y mejoras:**
 - ◆ **Objetivo:** asegurar un enfoque consistente y eficaz sobre la gestión de los incidentes de seguridad de la información, incluida la comunicación sobre eventos de seguridad y debilidades.
 - ◆ **Seguridad de la información en las relaciones con el proveedor:**
 - ◆ **Objetivo:** asegurar la protección de los activos de la organización a los que tiene acceso los proveedores.
 - ◆ **Gestión de entrega del servicio del proveedor:**
 - ◆ **Objetivo:** mantener un nivel acordado de seguridad de la información y entrega del servicio, en línea con los acuerdos del proveedor.

Anexo A 27002- 2022

Controles Organizacionales

- ◆ **Control de accesos.**
 - ◆ **Requisito del negocio para el control de acceso:**
 - ◆ **Objetivo:** restringir el acceso a la información y a las instalaciones de procesamiento de información.
 - ◆ **Gestión de accesos de usuarios:**
 - ◆ **Objetivo:** Asegurar el acceso de usuarios autorizados y evitar el acceso sin autorización a los sistemas y servicios.
 - ◆ **Responsabilidad del usuario:**
 - ◆ **Objetivo:** responsabilizar a los usuarios del cuidado de su información de autenticación.
 - ◆ **Control de acceso al sistema y aplicaciones:**
 - ◆ **Objetivo:** evitar el acceso sin autorización a los sistemas y aplicaciones.

Anexo A 27002- 2022

Controles orientados a las personas

- ◆ Seguridad de los recursos humanos.
 - ◆ **Previo al empleo:**
 - ◆ **Objetivo:** asegurar que los empleados y contratistas entiendan sus responsabilidades y que sean aptos para los roles para los cuales están siendo considerados.
 - ◆ **Durante la contratación**
 - ◆ **Objetivo:** Asegurar que los empleados y contratistas estén en conocimientos y cumplan con sus responsabilidades de la información.
 - ◆ **Finalización y cambios en la contratación**
 - ◆ **Objetivo:** proteger los intereses de la organización como parte del proceso de cambio o desvinculación del empleo.

Anexo A 27002- 2022

Controles orientados a la Seguridad Fisica

- ◆ **Seguridad física y del ambiente**

- ◆ **Áreas seguras:**

- ◆ **Objetivo:** evitar el acceso físico no autorizado, daños e interferencias contra las instalaciones de procesamiento de la información y la información de la organización.

- ◆ **Equipamiento:**

- ◆ **Objetivo:** Prevenir pérdidas, daños, hurtos o el compromiso de los activos así como la interrupción de las actividades de la organización.

Anexo A 27002- 2022

Controles Tecnologicos

◆ Seguridad de operaciones.

◆ Procedimiento y responsabilidades operacionales:

- ◆ **Objetivo:** asegurar la operación correcta y segura de las instalaciones de procesamiento de información.

◆ Código malicioso:

- ◆ **Objetivo:** Asegurar que la información y las instalaciones de procesamiento de la información sean protegidas contra código malicioso..

◆ Respaldo:

- ◆ **Objetivo:** proteger en contra de la pérdida de datos

◆ Registro y monitoreo:

- ◆ **Objetivo:** registrar evento y generar evidencias.

◆ Control del software de operación.

- ◆ **Objetivo:** Asegurar la integridad de los sistemas operacionales.

◆ Gestión de la vulnerabilidad técnica.

- ◆ **Objetivo:** evitar la explotación de las vulnerabilidades técnicas.

◆ Consideraciones a la auditoría de los sistemas de información.

- ◆ **Objetivo:** minimizar el impacto de las actividades de auditoría en los sistemas operacionales.

Anexo A 27002- 2022

Controles Tecnologicos

- ◆ **Seguridad en las comunicaciones.**

- ◆ **Gestión de la seguridad de red:**

- ◆ **Objetivo:** asegurar la protección de la información en las redes y sus instalaciones de procesamiento de información de apoyo.

- ◆ **Transferencia de información:**

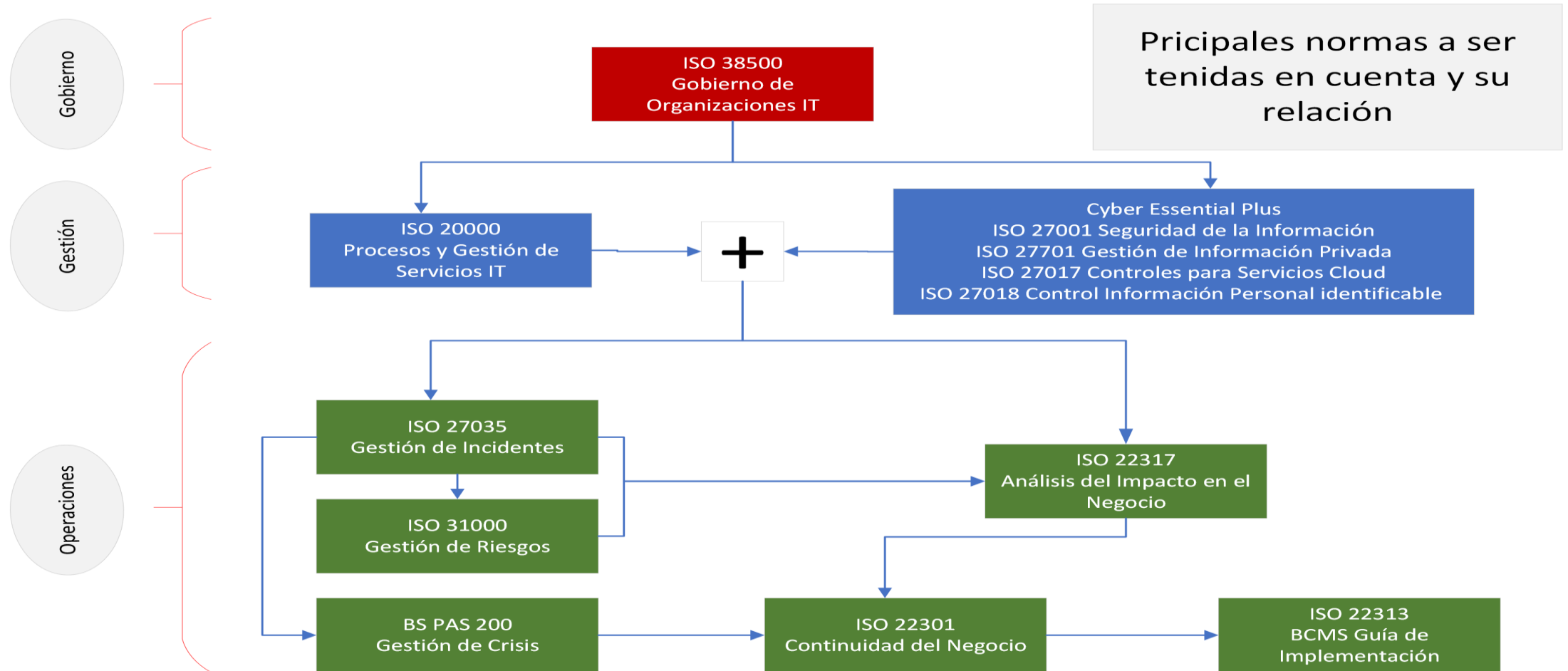
- ◆ **Objetivo:** mantener la seguridad de la información transferida dentro de una organización y con cualquier identidad externa.

Anexo A 27002- 2022

Controles Tecnologicos

- ◆ **Adquisición, desarrollo y mantenimiento de sistemas de información.**
 - ◆ **Requerimientos de seguridad de los sistemas de información:**
 - ◆ **Objetivo:** asegurar que la seguridad de la información es parte integral de los sistemas de información en todo el ciclo.
 - ◆ **Seguridad en los procesos de desarrollo y soporte:**
 - ◆ **Objetivo:** asegurar que la seguridad de la información está diseñada dentro del ciclo de desarrollo de los sistemas de información
 - ◆ **Datos de prueba:**
 - ◆ **Objetivo:** asegurar la protección de los datos usados para prueba.

Estandares y su relacion





UNIVERSIDAD NACIONAL
RAÚL SCALABRINI ORTIZ
SAN ISIDRO

@unsanisisidro



www.unso.edu.ar